PROCEDIMIENTO DE ADQUISICIÓN DE COMPONENTES IT

HISTORIAL DEL DOCUMENTO			
Versión	**Resumen de modificaciones**	**Fecha de entrada**	**Sustituye a (Código, revisión)**
01	Primera versión del documento.	26/02/2025	N/A

REGISTRO DE FIRMAS			
Función:	**Elaborado por:**	**Revisado por:**	**Aprobado por:**
Departamento:	Responsable del SGSI	Dirección	Jefe de seguridad (o suplente)
Nombre:	David Pozo	Carlos Rodrigo	Carlos Zúñiga
Firma:	Firmado por POZO SANCHEZ DAVID - ***6992** el día 26/02/2025	Firmado por RODRIGO RIVERO, CARLOS (AUTENTICACIÓN) el día	Firmado por ***8264** CARLOS ZUÑIGA (R: ****8690*) el día 26/02/2025 con un
Fecha:	26/02/2025	26/02/2025	26/02/2025

CONTENIDO

1 OBJETIVO 4
2 ALCANCE 4
3 DESARROLLO DEL PROCEDIMIENTO DE ADQUISICIÓN 4
3.1 DEFINICIÓN 4
3.2 RESPONSABILIDADES 5
3.3 CICLO DE VIDA DE LA COMPRA DE PRODUCTOS / COMPONENTES 5
3.3.1 Fase Previa 5
3.3.2 Aspectos a tener en cuenta para la compra de componentes 6
3.3.3 Ejecución 7
3.3.4 Extinción 7
3.4 ARCHIVO DE DOCUMENTOS 8
3.5 REVISIÓN 8
4 REFERENCIAS 9

1 OBJETIVO

El presente documento pretende establecer el marco técnico y procedimental en lo relativo a todas las actividades relacionadas con el procedimiento de compra y adquisición de nuevos componentes y servicios para los sistemas de información de SPIKA TECH.

El objetivo es detectar la necesidad de compra de posibles componentes necesarios y alinearlos con las necesidades de SPIKA TECH, cumpliendo con las medidas adecuadas y la arquitectura de seguridad, así como establecer las responsabilidades, los intervinientes y el método de realización de dichas adquisiciones.

2 ALCANCE

Este procedimiento se aplica en todos los sistemas de información que dan soporte a los servicios especificados que se incluyen en cada ámbito de actuación de SPIKA TECH, debiendo ser conocida y cumplida por todo el personal involucrado en la operación y mantenimiento de los mismos.

3 DESARROLLO DEL PROCEDIMIENTO DE ADQUISICIÓN

3.1 DEFINICIÓN

El procedimiento de adquisición de servicios y suministros, hace referencia a la descripción de los requisitos necesarios para gestionar la compra o adquisición de las necesidades TI el área de Ciberseguridad y de IT.

Se hace necesario que se determinen aspectos como:

- La gestión de solicitudes.
- El desarrollo de los requisitos.
- Las responsabilidades, roles y funciones.
- La identificación de la necesidad de adquirir un determinado componente.
- El análisis de los riesgos de ese componente y la aplicación de medidas oportunas.
- Su adecuación con la estructura de seguridad de la organización.
- Los recursos económicos y financieros.
- La profesionalidad de los intervinientes.

- La implicación de los cambios tecnológicos.

Así mismo, se para se cumplan los requisitos de formación y de concienciación del personal adjudicatario, pero también para que el personal encargado de realizar actividades relacionadas con la adquisición de nuevos suministros y servicios tenga la experiencia adecuada y formación específica que garantice el cumplimiento de los requisitos expuestos a lo largo de este documento.

Adicionalmente con el fin de atender a la evolución de la tecnología, se atenderán tanto a las necesidades técnicas como a la necesaria concienciación y formación de las personas que van a trabajar con los componentes adquiridos, para su correcto uso y mantenimiento adecuado, desde su implantación inicial y durante toda su vida útil.

3.2 RESPONSABILIDADES

Para cada proyecto de compra o adquisición y proceso de contratación, deben establecerse los roles y funciones de las personas que intervienen:

- **Unidad proponente (Área de Ciberseguridad o IT)**: es la unidad que realiza las solicitudes de adquisición de componentes / servicios TI /suministros.
- **Responsable del Contrato (RC**): Le corresponde supervisar la ejecución del contrato y adoptar las decisiones y dictar las instrucciones necesarias con el fin de asegurar la correcta realización de la prestación pactada.
- **Dirección**: es el órgano que tiene como objetivo establecer los presupuestos correspondientes a las distintas áreas.

Cuando se identifique la necesidad de un suministro por parte de un tercero se podrá proponer al responsable del Contrato correspondiente. No obstante, el proceso solo puede ser aprobado por la Dirección.

3.3 CICLO DE VIDA DE LA COMPRA DE PRODUCTOS / COMPONENTES

3.3.1 Fase Previa

De forma eventual, el primer paso realizar una serie de actuaciones preparatorias que plantean consultas preliminares al mercado y organizaciones, y cuya finalidad es preparar correctamente la adquisición de nuevos componentes IT o servicios.

3.3.2 Aspectos a tener en cuenta para la compra de componentes

3.3.2.1 Componentes seguros

Justificará y determinará la configuración de las ofertas con todas sus características.

En este sentido, antes de realizar una solicitud de adquisición, ha de **valorarse la necesidad de su compra** para las actividades y servicios prestados por SPIKA TECH.

Esta necesidad puede nacer atendiendo a las conclusiones de un análisis de riesgo previo o bien como consecuencia de la mejora de uno de los procesos. En tal caso, se justificará de donde nace la necesidad de su adquisición, describiendo cual es el elemento que se ha tenido en cuenta para determinar la adquisición.

Se tiene que establecer una **lista de elementos a tener en cuenta a la hora de adquirir componentes**.

Una vez realizada la justificación por la persona que realiza la solicitud, la persona encargada de su valoración decidirá si la aprueba o la rechaza en base a estos criterios.

En todo caso, se **utilizará el Catálogo de Productos y Servicios de Seguridad de las Tecnologías de la Información y Comunicación (CPSTIC) del CCN**, para seleccionar los productos o servicios suministrados por un tercero que formen parte de la arquitectura de seguridad del sistema y aquellos que se referencien expresamente en las medidas de este real decreto.

En el supuesto de que no existan productos o servicios en el CPSTIC que implementen las funcionalidades requeridas, se utilizarán productos con una certificación de **Common Criteria o LINCE.**

En la adquisición de nuevos componentes se tendrá en cuenta los resultados los posibles impactos, riesgos y otras consecuencias que pudiera implicar la adquisición del componente. Así mismo se tendrá en cuenta como prioritaria la adquisición de aquellos componentes que, conforme a las necesidades, se ajusten más adecuadamente al sistema de gestión de seguridad de la información de SPIKA TECH o contribuyan a su mejora.

3.3.3 Ejecución

Durante la ejecución del contrato y la prestación del servicio, se realizará un seguimiento periódico de los Acuerdos de Nivel de Servicios establecidos, y se evaluará por parte del Responsable del Contrato, entre otros, la necesidad de imponer penalidades o la necesidad de prorrogar su duración.

Una vez se haya realizado la entrega y formalizado la adjudicación, se procederá a realizar una revisión, de los distintos componentes, para verificar que todos los aspectos concretados en el pedido se corresponden con los del producto final que se recibe.

- **Suministro**: Se realiza acta de recepción. Se contrastará que la cantidad y estado del material concuerde con lo estipulado, así como las referencias. Los encargados de comprobar los componentes, examinarán que el software funciona conforme a las condiciones acordadas y que cumple las funciones para la que se destina. La organización supervisará y controlará el desarrollo de software que se realice de forma externa. Además, se comprobará que los recibos y facturas estén firmados incluyendo la fecha en la que los materiales/servicios/productos se han recibido.
- **Servicios:** Se realizan factura única o periódicas. Se verificará que el servicio se ejecute acorde a los términos acordados.

Si por algún motivo hay algún tipo de problema o incidencia con los componentes, se registrará en el recibo y se tramitará para que pueda resolverse con el adjudicatario.

3.3.4 Extinción

- Incumplimiento de las obligaciones contractuales:
  - Falta de entrega de los servicios acordados.
  - Incumplimiento de plazos u objetivos establecidos.
  - Incumplimiento de estándares de calidad especificados en el contrato.
- Retrasos injustificados.
  - Demoras constantes en la prestación del servicio.
  - Incapacidad para cumplir con los tiempos de entrega establecidos.
- Violación de términos y condiciones.
- Incumplimiento de políticas específicas (de seguridad, confidencialidad, etc.).

  - Uso indebido de información confidencial.
- Cambio en las circunstancias económicas o legales:
  - Modificaciones significativas en las leyes o regulaciones aplicables que afectan la viabilidad del contrato.
  - Cambios financieros graves que impidan el cumplimiento (insolvencia o quiebra).
- Subcontratación no autorizada:
  - Transferencia del servicio a terceros sin la autorización previa del cliente, si el contrato lo prohíbe.
- Negativa del cliente o proveedor a facilitar la cooperación necesaria para la ejecución del contrato:
  - Alteración del objeto del contrato.
- Cambios significativos en el alcance del servicio sin acuerdos formales:
  - Causas de fuerza mayor o caso fortuito.
- Eventos imprevisibles (desastres naturales, pandemias, conflictos) que impiden el cumplimiento del contrato.

3.4 ARCHIVO DE DOCUMENTOS

Toda la documentación relativa al proceso de compra como pueden ser el propio pedido, documentos de servicios contratados, presupuestos, contratos, ofertas o recibos, se archivarán dentro de los sistemas de SPIKA TECH en el sharepoint “Dirección/Finanzas y Presupuestos/Facturas”.

3.5 REVISIÓN

Para la revisión del presente procedimiento se tendrá en cuenta la evolución y cambios de la tecnología, la normativa y los estándares oficiales, así como de las necesidades de la organización y cualquier otro aspecto que implique un cambio en el proceso de adquisición de nuevos componentes. Todas las medidas de seguridad se reevaluarán y actualizarán periódicamente, para así adecuar su eficacia a la constante evolución de los riesgos y sistemas de protección, llegando incluso a un replanteamiento de la seguridad, si fuese necesario.

4 REFERENCIAS

- ISO/ IEC 27001:2022:
  - 5.8 Seguridad de la información en la gestión de proyectos.
  - 5.19 Seguridad de la información en las relaciones con los proveedores.
  - 5.20 Abordar la seguridad de la información dentro de los acuerdos con proveedores.